



Lecture Notes

Institute Name:	Silver Oak College of Computer Application		
Programme Name:	Master of Science Data Science	Semester:	1
Course Code:	DSM5061C	Course Name:	Information and Data Security
Unit No.:	2	Unit Name:	Data Privacy and Protection

1. Introduction to Data Privacy

Data privacy refers to the proper handling, collection, processing, storage, sharing, and disposal of information about individuals. It focuses on giving individuals appropriate control over their personal information and ensuring that organizations use data for legitimate and authorized purposes.

Data privacy is different from data security:

- **Data Privacy** → Concerned with **how data is collected, used, shared, and governed.**
- **Data Security** → Concerned with **protecting data from unauthorized access, modification, disclosure, or destruction.**

For example, encrypting a customer's database is a **security control**, while obtaining the customer's consent before collecting unnecessary information is a **privacy practice**.

Importance of Data Privacy

Data privacy is important because organizations collect large amounts of information through:

- Websites and mobile applications
- Banking and financial services
- Healthcare systems
- Educational platforms
- E-commerce systems
- Social media
- Government services
- IoT devices

Improper handling of this information can result in identity theft, financial fraud, reputational damage, legal penalties, and loss of customer trust.

2. Personal Data

Personal Data is any information that relates to an identified or identifiable individual.



The information may identify a person directly or may identify them when combined with other available information.

Examples

- Name
- Address
- Mobile number
- Email address
- Date of birth
- Photograph
- Employee ID
- Student ID
- IP address
- Location information
- Online identifiers
- Device identifiers

Example

Consider the following record:

Name	Email	Student ID	Course
Rahul Patel	rahul@example.com	ST101	MSc IT

The name, email address, and student ID are personal data because they can be associated with a particular individual.

Key Characteristics

Personal data may be:

1. **Directly identifiable** – name, Aadhaar number, passport number.
2. **Indirectly identifiable** – location, IP address, device identifier.
3. **Digital or physical** – electronic records as well as paper documents.
4. **Structured or unstructured** – database records, emails, images, documents, etc.

3. Sensitive Personal Data

Sensitive Personal Data refers to categories of personal information that require a higher level of protection because unauthorized disclosure or misuse may cause significant harm to an individual.

Examples may include:



- Passwords and authentication credentials
- Financial information
- Health information
- Biometric information
- Genetic information
- Certain information relating to identity or personal characteristics

The exact legal definition of sensitive data **depends on the applicable law or regulation.**

Example

A hospital database may contain:

Patient Name: ABC

Patient ID: P102

Blood Group: B+

Medical History: ...

Prescription: ...

Medical information requires stronger privacy and security controls than ordinary operational information.

Personal Data vs Sensitive Personal Data

Personal Data	Sensitive Personal Data
General information about an individual	Higher-risk personal information
Name	Health information
Email	Financial information
Phone number	Biometric information
Address	Authentication credentials
Student ID	Certain highly confidential personal records

Important: Sensitive data is still personal data, but it normally requires stronger protection.

4. Personally Identifiable Information (PII)



Personally Identifiable Information (PII) is information that can be used to identify, distinguish, or trace an individual, either by itself or together with other information.

Direct Identifiers

These can identify a person by themselves.

Examples:

- Full name
- Passport number
- Aadhaar number
- Driving licence number
- Employee ID

Indirect Identifiers

These may identify a person when combined with other information.

Examples:

- Date of birth
- ZIP/PIN code
- Gender
- Location
- IP address
- Device information

Example

Suppose a dataset contains:

Age = 22

Gender = Female

PIN Code = 380001

Individually, these values may not uniquely identify someone. However, when combined with other datasets, they may potentially identify a specific individual.

This is why privacy protection must consider **data linkage and re-identification risks**.

5. Data Privacy Principles

Data privacy principles provide guidelines for responsible collection and use of personal information.

5.1 Lawfulness, Fairness and Transparency



Data should be processed according to applicable legal requirements and in a fair and understandable manner.

Organizations should communicate:

- What data is being collected
- Why it is collected
- How it will be used
- Who may receive it
- How long it will be retained

5.2 Purpose Limitation

Personal data should be collected for **specific and legitimate purposes** and should not be used for unrelated purposes without appropriate justification.

Example

A university collects a student's mobile number for academic communication.

Using the same number for unrelated commercial advertising without an appropriate legal basis or permission may violate the principle of purpose limitation.

5.3 Data Minimization

Organizations should collect **only the data that is necessary** for the intended purpose.

Example

For an online examination registration form:

Required:

- Student ID
- Name
- Course
- Examination details

Potentially unnecessary:

- Personal social media account
- Unrelated family information
- Unnecessary financial information

Data minimization reduces privacy risks and the impact of potential breaches.

5.4 Accuracy



Personal data should be accurate and kept up to date where necessary.

Incorrect data can result in:

- Wrong decisions
- Incorrect records
- Financial loss
- Denial of services
- Administrative problems

5.5 Storage Limitation

Personal data should not be retained indefinitely.

Organizations should define:

- Retention period
- Archival requirements
- Deletion procedures
- Secure disposal mechanisms

5.6 Integrity and Confidentiality

Personal data should be protected against:

- Unauthorized access
- Unauthorized disclosure
- Accidental loss
- Destruction
- Modification

Security techniques such as encryption, access control, authentication, and backups support this principle.

5.7 Accountability

Organizations should be able to demonstrate that they follow privacy requirements.

This may involve:

- Privacy policies
- Audit records
- Access logs
- Data inventories
- Risk assessments
- Data protection procedures
- Employee training

6. Data Lifecycle Security

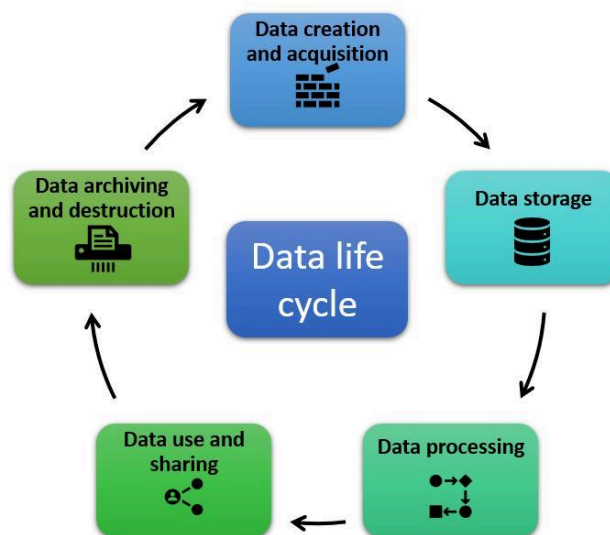
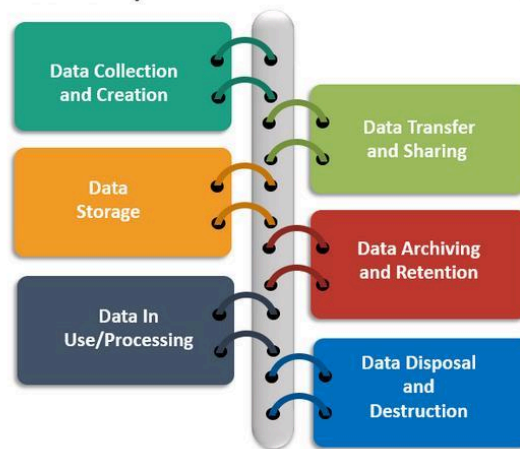
The **data lifecycle** represents the different stages through which data passes from its creation or collection to its final disposal.

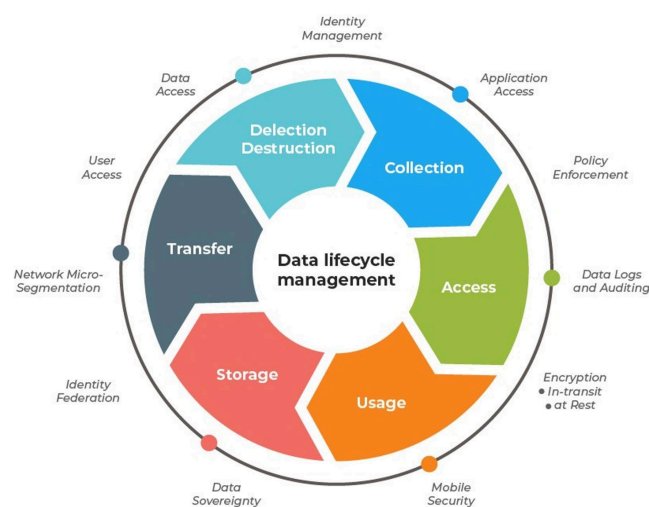
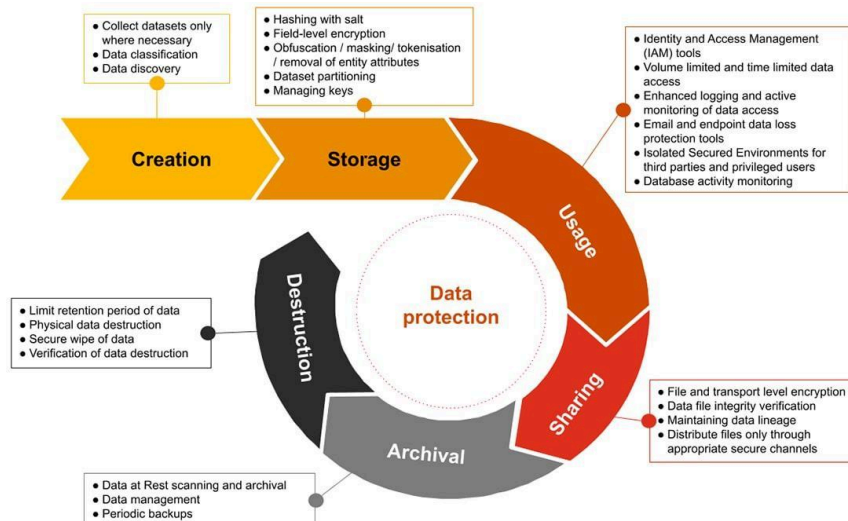
A typical lifecycle is:

Data Collection → Data Storage → Data Processing → Data Sharing → Data Disposal

Security and privacy controls should be applied at **every stage**.

The Data Lifecycle: A Framework for Secure Handling





7. Data Collection

Data Collection is the process of obtaining information from individuals, systems, devices, applications, or other sources.

Sources of Data

- Web forms
- Mobile applications
- Sensors
- CCTV systems
- Transaction systems
- Surveys
- Social media
- IoT devices
- Government databases

Privacy Considerations

During collection, organizations should consider:

- Is the data necessary?
- What is the purpose?
- Is the individual informed?
- Is an appropriate legal basis present?
- Is consent required?
- How much data should be collected?

Security Controls

- Secure web forms
- HTTPS/TLS
- Input validation
- Authentication
- Access control
- Anti-phishing mechanisms
- Secure APIs

Example

An e-commerce website needs a customer's delivery address to deliver an order. However, collecting unrelated information without a legitimate need increases privacy risk.

8. Data Storage

Data Storage refers to maintaining data in databases, servers, cloud platforms, computers, removable media, or physical records.

Storage Locations

- Database servers
- Cloud storage
- Local computers
- Data centres
- Mobile devices
- Backup systems
- External storage

Security Measures

Important controls include:

- Encryption at rest
- Strong authentication
- Role-Based Access Control (RBAC)
- Secure backups
- Database security
- Access logging
- Network segmentation
- Key management

Example

A university database containing student records should not allow every employee to access every record.

Instead:

Administrator → Full administrative access

Faculty → Academic information

Accounts Staff → Fee-related information

Student → Own records

This demonstrates the **principle of least privilege**.

9. Data Processing

Data Processing includes operations performed on data such as:

- Collection

- Organization
- Searching
- Analysis
- Modification
- Classification
- Aggregation
- Machine learning
- Reporting

Privacy Risks

Processing can create privacy risks when:

- Data is used for an unexpected purpose
- Excessive data is processed
- Data is combined with other datasets
- Automated decisions are made without appropriate safeguards

Security Measures

- Access control
- Encryption
- Secure processing environments
- Data masking
- Logging
- Monitoring
- Privacy-preserving analytics

Example

A university may analyze student performance data to identify students requiring academic support. The processing should be limited to the legitimate academic purpose.

10. Data Sharing

Data Sharing means providing data to another person, department, organization, application, or third-party service.

Types

- Internal sharing
- External sharing
- Third-party sharing
- Cross-border data transfer
- API-based sharing

Risks

- Unauthorized disclosure
- Data leakage
- Third-party misuse
- Excessive access
- Loss of control over data

Security Controls

- Access control
- Encryption during transmission
- Data-sharing agreements
- API authentication
- Data minimization
- Vendor/third-party assessment
- Audit logging

Example

A shopping application may share a customer's delivery address with a logistics provider. Only the information required for delivery should be shared.

11. Data Disposal

Data Disposal is the final stage of the data lifecycle in which data is securely deleted or destroyed when it is no longer required.

Simply deleting a file may not always be sufficient because data may remain in:

- Backups
- Temporary files
- Storage blocks
- Logs
- Cloud replicas

Secure Disposal Techniques

- Secure deletion
- Cryptographic erasure
- Media wiping
- Physical destruction
- Deletion of unnecessary backups
- Disposal of paper records through shredding

Example

When an organization retires a hard disk containing confidential records, simply deleting files is insufficient. The storage media should undergo an appropriate secure disposal process.

12. Data Classification

Data Classification is the process of categorizing data according to its sensitivity, value, confidentiality, and protection requirements.

A common classification model is:

Classification	Meaning	Example
Public	Can be freely shared	Public website content
Internal	Intended for organizational use	Internal procedures
Confidential	Unauthorized disclosure could cause harm	Employee records
Restricted	Highly sensitive information	Financial/health records

Organizations can define their own classification scheme according to their requirements.

Benefits

Data classification helps organizations determine:

- Who can access data
- Where data can be stored
- How data should be transmitted
- What encryption is required
- How long data should be retained
- How data should be disposed

Example

University Website → Public

Faculty Meeting Notes → Internal

Student Academic Records → Confidential

Authentication Credentials → Restricted

13. Data Masking

Data Masking is a technique that hides or replaces sensitive information while maintaining a useful representation of the data.

Example

Original:

Card Number: 4532123412345678

Masked:

Card Number: XXXX-XXXX-XXXX-5678

Another example:

Mobile Number: 9876543210

Masked: XXXXXXXX210

Types of Masking

- Static data masking
- Dynamic data masking
- Character substitution
- Shuffling
- Encryption-based masking
- Redaction

Applications

Data masking is commonly used in:

- Software testing
- Development environments
- Customer support
- Demonstration systems
- Analytics

Advantage

Developers can work with realistic-looking data without exposing actual sensitive information.

14. Data Anonymization

Data Anonymization is the process of modifying data so that individuals cannot reasonably be identified from the resulting dataset, considering reasonably available means.

Example

Original:

Name	Age	City	Disease
Rahul	25	Ahmedabad	Diabetes
Priya	26	Ahmedabad	Asthma

After anonymization:

Age Group	Region	Disease
20–30	Gujarat	Diabetes
20–30	Gujarat	Asthma

Direct identifiers have been removed or transformed, and identifying information is generalized.

Techniques

- Removing identifiers
- Generalization
- Aggregation
- Suppression
- Perturbation

Important Point

Anonymization is not simply deleting the name.

If other attributes can be combined with external information to identify an individual, re-identification may still be possible.

15. Data Pseudonymization

Pseudonymization replaces identifying information with artificial identifiers or pseudonyms.

Example

Original:



Name: Rahul Patel

Student ID: ST101

Pseudonymized:

Name: USER_501

Student ID: STUDENT_8A3F

The original identity may still be recoverable using additional information, such as a separate mapping table.

Example Architecture

Original Data



Pseudonymization



Pseudonymous Data



Processing / Analysis



Authorized Re-identification

The mapping information must be separately protected.

Pseudonymization vs Anonymization

Pseudonymization	Anonymization
Identity can potentially be restored	Identity is intended to be irreversibly removed
Uses pseudonyms	Removes/generalizes identifiers
Mapping information may exist	No identifying mapping should remain
Useful for controlled processing	Useful for privacy-preserving data release

Still requires privacy protection	May fall outside personal-data scope only if genuinely anonymized under applicable law
-----------------------------------	--

16. Data Masking vs Anonymization vs Pseudonymization

Technique	Main Purpose	Can Original Identity Be Recovered?	Example
Data Masking	Hide sensitive values	Usually the underlying data remains available to authorized systems	XXXX-5678
Anonymization	Prevent identification	Intended to prevent reasonable re-identification	Age group instead of exact DOB
Pseudonymization	Replace identifiers	Yes, if additional information is available	USER_1024

Simple Memory Trick

Masking → Hide

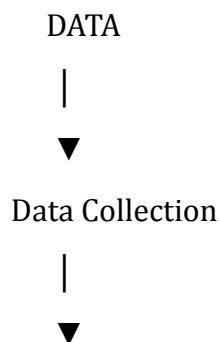
Anonymization → Remove identity

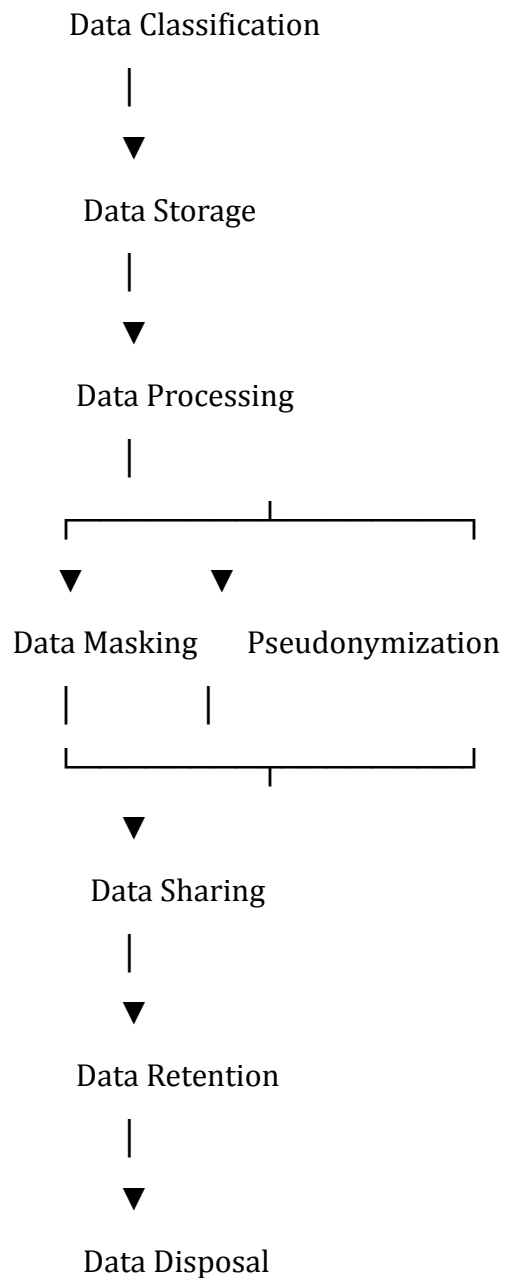
Pseudonymization → Replace identity

17. Integrated Data Privacy Lifecycle

The concepts can be combined into one privacy-aware workflow:

DATA PRIVACY LIFECYCLE





At each stage, organizations should apply appropriate privacy and security controls.

18. Real-World Example: University Student Data

Consider a university managing student information.

Collection

The university collects:

- Student name
- Enrollment number



- Contact details
- Academic records

Classification

Name → Personal

Mobile → Personal

Academic Record → Confidential

Password → Highly Restricted

Storage

Student records are stored in a secured database with:

- Authentication
- RBAC
- Encryption
- Audit logs

Processing

Faculty members use academic records for:

- Attendance analysis
- Result preparation
- Academic performance analysis

Sharing

Only relevant information is shared with authorized departments.

Protection

For software testing:

Rahul Patel

↓

USER_1001

or

9876543210

↓

XXXXXX3210

Disposal

When records are no longer required according to the applicable retention policy, they are securely deleted or destroyed.

1. Secure Data Handling

Secure data handling refers to the systematic practices used to protect data throughout its lifecycle against unauthorized access, disclosure, modification, loss, theft, or destruction.

Secure handling applies to:

Data Collection → Data Storage → Data Processing → Data Sharing → Data Backup → Data Disposal

The main objectives are:

- Maintain **Confidentiality**
- Maintain **Integrity**
- Maintain **Availability**
- Prevent unauthorized disclosure
- Reduce data loss and leakage
- Support privacy and regulatory compliance

2. Secure File Sharing

Secure file sharing is the process of transferring or providing access to files while protecting them from unauthorized access, modification, interception, or accidental disclosure.

Common File-Sharing Methods

- Email attachments
- Cloud storage
- Secure file-transfer systems
- Organizational collaboration platforms
- Secure APIs
- Network file shares
- Removable storage devices

Security Risks

Normal file sharing can create risks such as:

- Sending files to the wrong person
- Unauthorized access
- Malware infection



- Data interception
- Publicly accessible links
- Accidental data leakage
- Loss of control over shared files

Secure File-Sharing Practices

2.1 Access Control

Only authorized users should be allowed to access a file.

For example:

Student Records



Faculty → View

HOD → View + Modify

Administrator → Full Access

Unauthorized User → Denied

The **principle of least privilege** should be applied.

2.2 Encryption

Sensitive files should be protected using encryption.

Two important forms are:

Encryption in transit

Protects data while it is being transferred.

Encryption at rest

Protects stored data.

For example:

Sender



Encrypted File



Secure Transmission





Authorized Receiver



Decryption

2.3 Password-Protected Files

Sensitive documents can be protected using strong passwords.

Examples:

- Confidential reports
- Financial statements
- Employee records
- Examination documents

Passwords should not be sent through the same communication channel as the protected file.

2.4 Expiring Links

Cloud-sharing systems may provide links that automatically expire.

Example:

File Link Created



Valid for 24 Hours



Recipient Downloads File



Link Expires

This reduces the risk of long-term unauthorized access.

2.5 Access Logs

Organizations should maintain logs showing:

- Who accessed the file
- When it was accessed
- What action was performed
- Whether the file was downloaded or modified

2.6 Secure File-Sharing Checklist

Practice	Purpose
Authentication	Verify user identity
Authorization	Control access
Encryption	Protect file contents
Expiring links	Reduce long-term exposure
Access logs	Monitor file usage
Data classification	Determine protection requirements
Secure deletion	Remove unnecessary copies

3. Data Backup and Recovery

Data backup is the process of creating additional copies of data so that the information can be restored after accidental deletion, hardware failure, cyberattack, or disaster.

Data recovery is the process of restoring data and systems after data loss or disruption.

Why Backup is Important

Data may be lost because of:

- Hardware failure
- Human error
- Malware
- Ransomware
- Accidental deletion
- Software failure
- Natural disasters
- Power failure
- Theft

3.1 Types of Backup

Full Backup

A full backup copies all selected data.



Monday

Full Backup → All Data

Advantages:

- Simple restoration
- Complete copy

Disadvantage:

- Requires more storage and time

Incremental Backup

An incremental backup stores changes made since the **most recent backup**.

Example:

Monday → Full Backup

Tuesday → Changes since Monday

Wednesday → Changes since Tuesday

Thursday → Changes since Wednesday

Advantages:

- Requires less storage
- Faster backup

Disadvantage:

- Restoration may require multiple backup sets

Differential Backup

A differential backup stores changes made since the **last full backup**.

Monday → Full Backup

Tuesday → Changes since Monday

Wednesday → Changes since Monday + Tuesday

Thursday → Changes since Monday + Tuesday + Wednesday

It generally requires more storage than incremental backup but can simplify restoration.

4. 3-2-1 Backup Strategy

The **3-2-1 backup strategy** is a widely used backup approach:

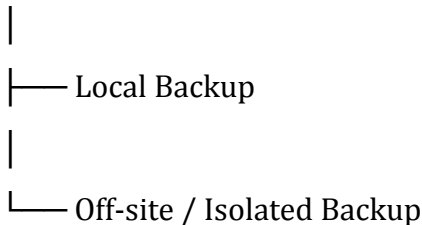
3 → Maintain three copies of important data

2 → Store them on two different types of media/storage

1 → Keep at least one copy off-site or otherwise isolated from the primary environment

Example:

Original Data



For stronger ransomware resilience, organizations may use **offline or immutable backups**.

5. Backup Security

Backup systems themselves contain sensitive information and therefore require protection.

Important controls include:

- Encryption
- Access control
- Multi-factor authentication
- Backup monitoring
- Backup integrity checks
- Offline or isolated copies
- Retention policies
- Regular recovery testing

Important Principle

A backup is useful only if it can actually be restored.

Therefore, organizations should periodically perform **restore tests**.

6. Data Recovery

Data recovery involves restoring data and services after an incident.

A basic recovery process is:

Incident



Identify Data Loss



Select Appropriate Backup



Verify Backup Integrity



Restore Data



Validate Data



Resume Operations

Recovery Planning

Organizations should define:

- What data must be recovered first?
- How quickly must systems be restored?
- Who is responsible for recovery?
- Where are backups stored?
- How will backup integrity be verified?

6.1 Recovery Time Objective (RTO)

RTO specifies the maximum acceptable time required to restore a service after disruption.

Example:

RTO = 2 Hours

This means the organization aims to restore the service within two hours.

6.2 Recovery Point Objective (RPO)

RPO specifies the maximum acceptable amount of data loss measured in time.

Example:

RPO = 30 Minutes

This means the organization should be able to recover data to a point no more than approximately 30 minutes before the disruption, depending on the backup/replication design.

RT0 vs RPO

RT0	RPO
Focuses on time to restore service	Focuses on acceptable data loss
Measured in time	Measured in time
"How quickly can we recover?"	"How much recent data can we afford to lose?"

7. Secure Data Storage

Secure data storage means protecting stored data against unauthorized access, modification, disclosure, loss, and destruction.

Data may be stored in:

- Databases
- File servers
- Cloud platforms
- Laptops
- Mobile devices
- External hard drives
- Backup systems

7.1 Encryption at Rest

Encryption protects stored information from unauthorized access.

Example:

Plaintext Data



Encryption



Encrypted Data



Secure Storage

Even if an unauthorized person obtains the storage media, encrypted data is significantly harder to use without the required cryptographic key.

7.2 Access Control

Access should be granted according to job responsibilities.

Example:

User	Access
Student	Own academic records
Faculty	Assigned students
HOD	Department-level records
System Administrator	System administration
Unauthorized User	No access

7.3 Authentication

Users should be properly authenticated before accessing sensitive systems.

Common mechanisms:

- Passwords
- Multi-factor authentication
- Biometrics
- Security tokens
- Digital certificates

7.4 Data Integrity

Stored data should be protected from unauthorized modification.

Controls include:



- Hashing
- Digital signatures
- Access controls
- Audit logs
- File integrity monitoring

8. Privacy Risks in Digital Ecosystems

A **digital ecosystem** consists of interconnected applications, platforms, users, organizations, devices, networks, and data services.

Examples:

- Social media
- E-commerce
- Mobile applications
- Cloud services
- IoT
- Digital payment systems
- Online education platforms
- Healthcare applications

These ecosystems generate enormous amounts of personal data.

9. Digital Footprint

A **digital footprint** is the trail of information generated by an individual's activities in the digital environment.

Types of Digital Footprints

9.1 Active Digital Footprint

Information intentionally shared by the user.

Examples:

- Social media posts
- Comments
- Online reviews
- Uploaded photographs
- Online forms

9.2 Passive Digital Footprint



Information collected or generated without the user directly publishing it.

Examples:

- Website activity
- Cookies
- IP addresses
- Device information
- Location information
- Browsing patterns

Digital Footprint Example

User



Searches



Websites Visited



Online Purchases



Social Media Activity



Location Data



Digital Footprint

10. Risks Associated with Digital Footprints

Large digital footprints can create risks such as:

- Identity theft
- Targeted scams
- Profiling
- Behavioral tracking
- Reputation damage
- Social engineering
- Unauthorized data sharing
- Targeted advertising



- Privacy loss

Example

Suppose a person publicly shares:

Name

+

Date of Birth

+

Location

+

Workplace

+

Travel Plans

An attacker may combine these details with information from other sources to perform social engineering or identity-related attacks.

11. Social Media Privacy

Social media platforms allow users to share:

- Photographs
- Videos
- Personal opinions
- Location
- Relationships
- Education
- Employment details
- Events
- Interests

However, excessive sharing can create privacy risks.

Common Social Media Privacy Risks

1. Oversharing
2. Location exposure
3. Fake profiles
4. Identity theft

5. Social engineering
6. Unauthorized screenshots
7. Third-party application access
8. Data profiling
9. Account takeover
10. Permanent digital records

11.1 Social Media Privacy Best Practices

Users should:

- Use strong and unique passwords
- Enable multi-factor authentication
- Review privacy settings
- Limit public information
- Avoid sharing sensitive documents
- Be careful with unknown links
- Review connected applications
- Avoid posting real-time location unnecessarily
- Review tagged photographs
- Periodically audit old posts

Example

Instead of publicly posting:

"I am leaving my home for a two-week vacation."

A safer approach is to avoid announcing real-time absence publicly.

12. Data Privacy Challenges in Analytics

Data analytics involves collecting, processing, combining, and analyzing data to discover patterns and support decision-making.

Although analytics provides significant benefits, it can create privacy risks.

12.1 Excessive Data Collection

Analytics systems may collect more information than necessary.

Example:

A shopping company wants to analyze purchasing patterns but collects unnecessary personal information unrelated to that analysis.



12.2 Re-identification

A dataset may appear anonymous but individuals may be identified by combining it with other datasets.

Example:

Dataset A

Age + PIN Code + Gender

+

Dataset B

Public Records

↓

Possible Re-identification

Therefore, simply removing names does not automatically guarantee anonymity.

12.3 Data Linkage

Different datasets can be combined to generate additional information about an individual.

For example:

Healthcare Data

+

Location Data

+

Purchase Data

↓

Detailed Individual Profile

This can create significant privacy concerns.

12.4 Profiling

Analytics can be used to create profiles based on:

- Behaviour
- Purchases
- Location
- Interests
- Online activities
- Preferences

Profiling can become problematic when individuals are evaluated or categorized without appropriate transparency or safeguards.

12.5 Bias and Unfair Decisions

Analytics and AI systems may produce unfair outcomes when datasets contain:

- Historical bias
- Incomplete data
- Unrepresentative samples
- Incorrect labels

Therefore, privacy-aware analytics should consider both **data protection and responsible use of data**.

13. Organizational Data Protection

Organizations handle large quantities of:

- Customer information
- Employee information
- Financial data
- Business information
- Intellectual property
- Authentication credentials
- Research data

A structured data protection program is required to manage these assets.

14. Data Protection Policies

A **data protection policy** is a formal organizational document defining how data must be collected, accessed, processed, stored, shared, retained, and disposed of.

Main Components

A data protection policy may define:

1. Purpose of data collection
2. Data classification
3. Access control
4. Data storage requirements
5. Encryption requirements
6. Data-sharing rules
7. Backup requirements
8. Retention periods
9. Secure disposal
10. Incident reporting
11. Employee responsibilities
12. Third-party data handling
13. Monitoring and auditing

14.1 Example Policy Statement

An organization may specify:

Confidential information must only be accessed by authorized personnel and must not be transferred through unauthorized personal storage or communication services.

This converts privacy and security requirements into an operational rule.

15. Data Handling Best Practices

Employees are one of the most important components of organizational data protection.

Best Practices

15.1 Collect Only Necessary Data

Follow the principle of **data minimization**.

15.2 Classify Data

Identify whether information is:

- Public
- Internal
- Confidential
- Restricted



15.3 Use Strong Authentication

Use:

- Strong passwords
- Password managers where appropriate
- Multi-factor authentication

15.4 Apply Least Privilege

Users should receive only the access required for their job.

15.5 Encrypt Sensitive Data

Protect sensitive data during:

- Storage
- Transmission
- Backup

15.6 Use Approved Storage

Employees should store organizational information only on authorized systems.

Avoid storing confidential information on:

- Personal USB drives
- Personal cloud accounts
- Unapproved applications
- Unsecured devices

15.7 Secure File Sharing

Verify:

- Recipient
- File sensitivity
- Permission settings
- Sharing link
- Expiration date

15.8 Secure Disposal

Do not simply throw confidential documents into normal waste.

Use appropriate:

- Secure deletion



- Media wiping
- Shredding
- Physical destruction

15.9 Report Incidents

Employees should immediately report:

- Lost devices
- Wrong email recipients
- Suspicious links
- Unauthorized access
- Accidental disclosure
- Missing files

16. Data Loss Prevention Awareness

Data Loss Prevention (DLP) refers to processes and technologies designed to detect, monitor, and prevent unauthorized disclosure, transfer, or loss of sensitive information.

DLP helps answer:

What sensitive data is leaving the organization, who is sending it, where is it going, and whether that transfer is authorized?

16.1 Common DLP Channels

DLP controls may monitor:

- Email
- Web uploads
- Cloud storage
- USB devices
- Endpoints
- Network traffic
- Printing
- Collaboration platforms

Example

Suppose an employee attempts to email a confidential customer database to a personal email account.

A DLP system may detect:

Confidential Data



Personal Email



DLP Detection



Policy Violation



Block / Alert / Record

17. DLP Controls

DLP solutions may perform actions such as:

Monitor

Record suspicious activity.

Alert

Notify security personnel.

Block

Prevent unauthorized transfer.

Quarantine

Temporarily isolate the data or message.

Encrypt

Apply protection before transmission.

Audit

Maintain records for investigation.

18. Human Awareness and Data Protection

Technology alone cannot guarantee data protection.

Employees may accidentally cause data exposure through:

- Incorrect email recipients
- Weak passwords
- Lost devices
- Phishing attacks
- Unauthorized cloud storage
- Unapproved applications
- Poor disposal practices
- Sharing credentials

Therefore, organizations should conduct regular:

- Security awareness training
- Privacy awareness programs
- Phishing simulations
- Data handling training
- Incident reporting exercises

19. Integrated Example: College Data Protection

Consider a college that manages student information.

Data Collected

Student Name

Enrollment Number

Mobile Number

Email

Attendance

Marks

Fee Information

Classification

Public

↓

College Website Information

Internal

↓

Department Circulars



Confidential



Student Academic Records

Restricted



Authentication Credentials

Secure Storage

The college uses:

- Access control
- Encryption
- Authentication
- Backup
- Audit logs

Secure Sharing

Marks are shared only with authorized students and faculty.

Backup

Regular backups are maintained, including an appropriately isolated copy.

DLP

If an employee attempts to send a large student database to a personal email account:

Employee



Attempts Data Transfer



DLP Detects Sensitive Data



Policy Evaluation



Block / Alert



Security Team Review

Disposal

When records reach the end of their approved retention period, they are securely deleted or destroyed.

20. Secure Data Handling Framework

The complete concept can be represented as:

